СБЕР
КИБЕР
БЕЗОПАСНОСТЬ

Аудит безопасности СУБД StarRocks 4.1.7



Соответствие корпоративному стандарту КБ
по требованиям 2.1–5.6

Черновик · ноябрь 2026

Материалы для владельца риска КБ

СБЕР
КИБЕР
БЕЗОПАСНОСТЬ

StarRocks 4.1.7 в конфигурации по умолчанию **не соответствует** стандарту.

Эксплуатация допустима **только как принятый риск КБ.**

Защиту прикладных данных от администраторов СУБД **в текущей архитектуре обеспечить нельзя** — риск снижается, но не устраняется.

Объект и метод аудита

СБЕР КИБЕР БЕЗОПАСНОСТЬ

объект

4.1.7

StarRocks, тег от 22.10.2026

Commit b81ff9cc. Shared-nothing — исходный код и стенд; shared-data — исходный код, частично.

критериев

76

атомарных проверок по стандарту

Каждое требование 2.1–5.6 разложено на проверяемые критерии и прослежено до кода и теста.

тестов на стенде

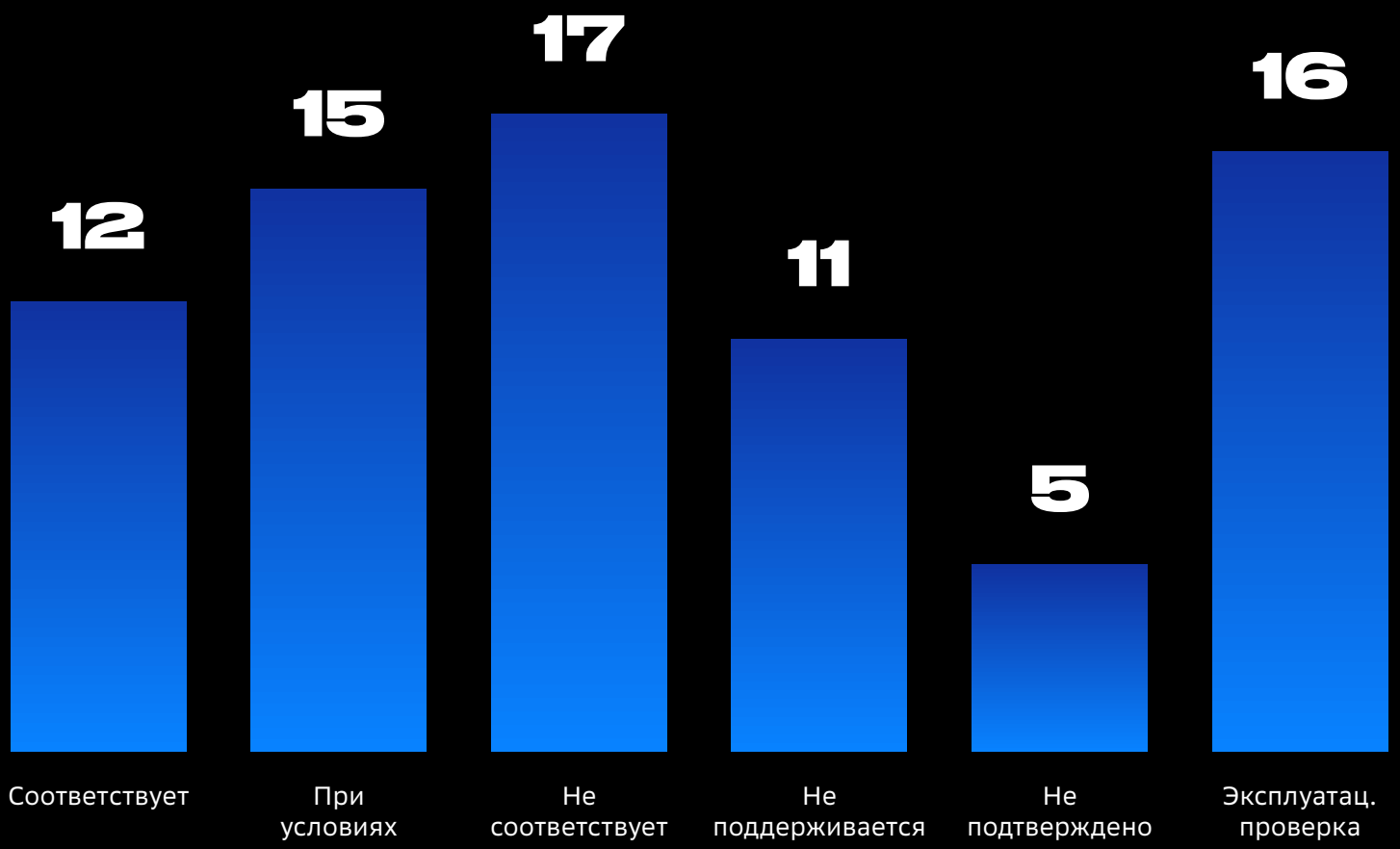
29

воспроизводимых проверок

Изолированный Docker-стенд, синтетические данные. Проверены и недостатки, и меры защиты.

Результат по 76 критериям стандарта

СБЕР КИБЕР БЕЗОПАСНОСТЬ



28

критериев не соответствуют или механизм отсутствует в продукте

27

соответствуют, из них 15 — только при выполнении условий

Доля проверенных критериев — показатель охвата аудита, а не уровня защищённости.

СБЕР
КИБЕР
БЕЗОПАСНОСТЬ

Ключевые риски



Четыре группы рисков

СБЕР КИБЕР БЕЗОПАСНОСТЬ

ДОСТУП АДМИНИСТРАТОРОВ К ДАННЫМ

Встроенные роли root, db_admin и user_admin имеют прямой или косвенный доступ к прикладным данным

4.5 · F-01, F-02, F-04

СЛУЖЕБНЫЕ ФУНКЦИИ ПО УМОЛЧАНИЮ

Отладочные и служебные возможности включены и расширяют полномочия администраторов

3.3, 4.1, 4.5 · F-03, F-11

АУТЕНТИФИКАЦИЯ

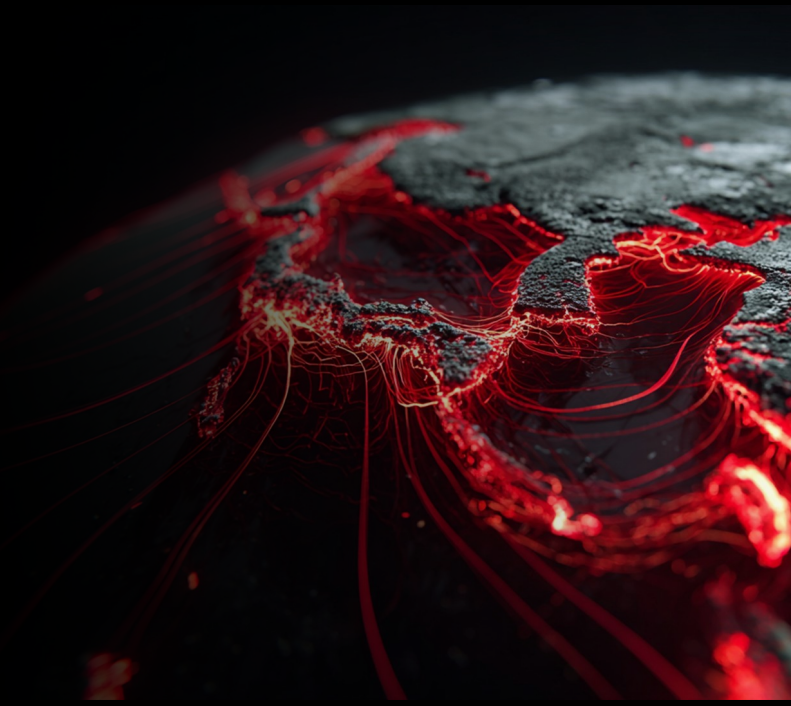
Нет парольной политики и блокировки учётных записей; пустой пароль root после установки

4.2, 4.8 · F-04, F-05

ЗАЩИТА КАНАЛОВ И АУДИТ

Межузловые каналы без TLS; часть HTTP-интерфейсов без аутентификации; аудит неполон

2.4, 4.3, 5.1 · F-06, F-07, F-09



Административные роли и доступ к данным

СБЕР КИБЕР БЕЗОПАСНОСТЬ

Роль	Назначение	Доступ к прикладным данным
root (встроенная)	Аварийный доступ	**Да — полный, ограничить нельзя**
db_admin (встроенная)	Администрирование объектов БД	**Да — напрямую**
user_admin (встроенная)	Управление учётными записями	**Да — через выдачу прав себе**
security_admin (встроенная)	Безопасность и конфигурация	**Да — до отключения служебных функций**
cluster_admin (встроенная)	Узлы кластера	**Не подтверждено**
«DBA без данных» (своя роль)	Администрирование схемы	**Нет — проверено 12 путей**

Своя роль «DBA без данных» не читает данные, но видит часть метаданных и может изменять схему (F-14).

Меры защиты проверены на стенде

СБЕР КИБЕР БЕЗОПАСНОСТЬ

Мера	Требование	Результат проверки
Обязательный TLS для клиентских подключений	2.4	**Работает; localhost — исключение**
Аутентификация HTTP-интерфейсов FE и BE	4.3, 5.5	**Работает**
Отключение служебных скриптов FE	4.1, 4.5	**Работает**
Аудит входов и неуспешных попыток	5.1	**Работает; выход не регистрируется**
Своя роль «DBA без данных»	4.5	**Работает; остаются метаданные**

Профиль настроек — в полном отчёте, §11.2. Не проверены на целевой конфигурации: шифрование межузлового трафика, отзыв прав в открытой сессии.

Что не устраняется настройкой продукта

СБЕР КИБЕР БЕЗОПАСНОСТЬ

01

Встроенные роли видят данные

root, db_admin и user_admin неизменяемы и сохраняют доступ к прикладным данным

Требование 4.5

02

Нет парольной политики

Длина, срок действия и блокировка учётных записей не поддерживаются

Требование 4.8, 5.1

03

Межузловые каналы без TLS

Внутренние протоколы кластера не шифруются, узлы не аутентифицируют друг друга

Требование 2.4

04

Пробелы штатного аудита

Нет события выхода пользователя и атрибута «приложение»

Требование 5.1, 5.2

Компенсация — только внешними мерами: PAM, DAM, сетевая сегментация, внешняя аутентификация — или исправлениями вендора.

Условия допустимости эксплуатации

СБЕР КИБЕР БЕЗОПАСНОСТЬ

1. Применён и проверен профиль безопасной конфигурации
2. Встроенные административные роли не выдаются людям; root — только аварийный доступ через PAM
3. Кластер в изолированном сегменте, межузловой трафик шифруется инфраструктурой
4. Привилегированные учётные записи — через PAM с записью сессий; установлен DAM
5. Аутентификация пользователей через СУДИР/LDAP по защищённому каналу
6. Аудит в реальном времени доставляется в ПКБ, настроены правила на действия администраторов
7. Риски по F-01, F-03, F-05, F-09 заведены и приняты в установленном порядке



Решение владельца риска

СБЕР КИБЕР БЕЗОПАСНОСТЬ

принять риск

2.1

Оформить риск КБ по п. 2.1

Типовой риск — доступ с повышенными привилегиями; мероприятия по минимизации и принятие владельцем АС/ФП.

не размещать

PCI DSS

Данные карт и финансовых АС

Без исправлений вендора по F-01, F-05, F-07, F-09 соответствие для этих зон не достигается.

запросить у вендора

6

исправлений в продукте

Разделение ролей, парольная политика, полный аудит, TLS межузлового трафика и безопасные значения по умолчанию.

СБЕР
КИБЕР
БЕЗОПАСНОСТЬ

Спасибо!

Полный отчёт, матрица требований и доказательства — в материалах аудита (каталог audit/)

